

scripts/sonar-scan.sh — User Guide

Last verified: 2026-06-04 (completeness program, Phase 2C) **Inheritance:** HelixConstitution §11.4.18 (script documentation mandate)

Overview

scripts/sonar-scan.sh is thin Lava-side glue that brings up the local, rootless SonarQube Community Edition stack (docker-compose.sonar.yml) and runs the sonarsource/sonar-scanner-cli container against the workspace. It is the operator entry point for static-analysis + coverage aggregation; the analysis configuration lives in sonar-project.properties.

Per §6.U it NEVER uses sudo/su. Per §6.R the SONAR_TOKEN is read from .env (or the environment) and is NEVER hardcoded. Per §6.J it does not bluff: a scan is run only against a server that reports status UP, and a failed scan exits non-zero rather than printing a fake pass.

Usage

```
./scripts/sonar-scan.sh up      # bring up the local Sonar +  
                               Postgres stack  
./scripts/sonar-scan.sh status # poll /api/system/status until UP  
./scripts/sonar-scan.sh scan   # run the scanner (default if no  
                               subcommand)  
./scripts/sonar-scan.sh down   # tear the stack down
```

Prerequisites

- A rootless container runtime: **podman** (preferred) or **docker**. Detected automatically; no sudo.
- SONAR_TOKEN in .env for the scan subcommand. Generate it in the local Sonar UI (<http://127.0.0.1:9000> → My Account → Security → Generate Tokens) after first bring-up + admin password change.
- For Kotlin coverage + Detekt findings and Go coverage to appear in the Sonar dashboard, the Phase-2A (Detekt + Kover) and Phase-2B (Go coverage) reports must have been generated first. The scanner skips any absent report file.

Outputs

- Scanner stdout/stderr captured to .lava-ci-evidence/completeness-program/sonar/<date>/scanner-output.log.

Known blocker (honest, this host)

SonarQube embeds Elasticsearch, which on most Linux container runtimes requires the kernel parameter `vm.max_map_count >= 262144`. Setting that value needs root, which §6.U forbids in this project's scripts. Therefore:

- On a host where the value is already sufficient, up succeeds.
- Where it is too low, the sonarqube container's ES sub-process refuses to start (the container stays unhealthy). Raising the value is an OPERATOR / GATE-HOST action performed outside this project's scripts — see `docs/security/2026-06-04-sonarqube-snyk-setup.md` for the exact step per OS.

Maintenance

When this script changes, update this document in the same commit (CM-SCRIPT-DOCS-SYNC, §11.4.18).

Cross-references

- `scripts/sonar-scan.sh` — the script itself
- `docker-compose.sonar.yml` — the local server + db stack
- `sonar-project.properties` — analysis configuration
- `docs/security/2026-06-04-sonarqube-snyk-setup.md` — full setup + blockers